

Risikoanalyse — Website der Praxis Birgit Kretzschmar

Dokumentversion: Entwurf 1, 14. Mai 2026 **Autor:** Dr. Henry Macartney (Beriot GmbH) **Projekt:** Website-Erstellung Praxis Kretzschmar **Quelldokument:** User Requirements Specification — Website der Praxis Birgit Kretzschmar (v1.0) **Status:** Entwurf. Gemeinsam mit der URS zu prüfen.

1. Zweck und Methode

Dieses Dokument ist eine Risikoanalyse der Anforderungen, die in der User Requirements Specification (URS) für die Praxis-Website von Birgit Kretzschmar erfasst sind. Für jede Anforderung benennt es das zugehörige Risiko — was in Bezug auf diese Anforderung schiefgehen könnte —, klassifiziert dieses Risiko und gibt, wo das Risiko **hoch** ist, eine mindernde Maßnahme an, die das Risiko entweder beseitigt oder auf **niedrig** reduziert.

1.1 Anforderungskennzeichnung

Die URS ist nicht als nummerierte Anforderungsliste verfasst; die Anforderungen sind in ihren Abschnitten eingebettet. Zur Nachverfolgbarkeit wurde jeder einzelnen Anforderung eine eindeutige Kennung mit folgenden Präfixen zugewiesen:

- **CON-** — eine Rahmenbedingung (URS § 5)
- **SCOPE-** — eine Umfangsabgrenzung (URS § 6)
- **AC-** — ein Abnahmekriterium (URS § 7)
- **BLD-** — eine Anforderung der Build-Spezifikation (URS § 4)

Jede Zeile der Traceability-Matrix in § 3 verfolgt eine Anforderungskennung zurück zu ihrem Quellabschnitt in der URS.

1.2 Klassifizierungssystem

Klassifizierung	Bedeutung
Hoch	Wahrscheinlich eintretend und/oder schwerwiegende Folge (veröffentlichungsverhindernd, rechtliche Exposition oder Schädigung des Patientenvertrauens). Ein hohes Risiko muss in diesem Dokument eine mindernde Maßnahme tragen.
Mittel	Plausibles Eintreten mit beherrschbarer Folge oder schwerwiegende Folge bei geringer Wahrscheinlichkeit. Wird überwacht; Minderung ratsam, aber nicht zwingend.
Niedrig	Unwahrscheinlich und/oder geringfügige Folge. Akzeptiert ohne zwingende Maßnahme.

1.3 Minderungsregel

Jede als **hoch** klassifizierte Anforderung erhält eine mindernde Maßnahme, deren Wirkung darin besteht, das Risiko zu beseitigen oder auf **niedrig** zu reduzieren. Die Matrix zeigt die **Restklassifizierung** — die Klassifizierung, die gilt, sobald die mindernde Maßnahme umgesetzt ist —, sodass die Reduktion ausdrücklich und nachprüfbar ist.

2. Risikoübersicht

Klassifizierung (vor Minderung)	Anzahl
Hoch	6
Mittel	8
Niedrig	6
Bewertete Anforderungen insgesamt	20

Nach Umsetzung der mindernden Maßnahmen in § 3 reduzieren sich alle sechs hohen Risiken auf niedrig. Es verbleiben keine hohen Restrisiken.

3. Traceability-Matrix

Jede Zeile verfolgt eine einzelne Anforderung zu ihrem Risiko, ihrer Klassifizierung und — wo hoch — ihrer mindernden Maßnahme und Restklassifizierung.

3.1 Rahmenbedingungen (URS § 5)

Anf.-ID	Anforderung (kurz)	Quelle	Risiko	Klasse	Mindernde Maßnahme (hohe Risiken)	Rest
CON-01	Keine Patientendaten auf der Website	§ 5	Eine künftige Funktionsanforderung (Buchung, Aufnahmeformular) führt einen Pfad für Patientendaten ein und schafft eine DSGVO-Haftung, die die Website gerade vermeiden sollte	Hoch	Die Umfangsabgrenzung SCOPE-03 hält den Ausschluss formal fest; jede Änderung, die Patientendaten einführt, erfordert vor dem Build eine neue URS und eine ausdrückliche DSGVO-Bewertung. Das Change-Control-Gate macht es unmöglich, den Pfad unbemerkt hinzuzufügen.	Niedrig
CON-02	DSGVO-Konformität; Fonts, Formulare, eingebundene Ressourcen dokumentierbar	§ 5	Google Fonts werden bei der Veröffentlichung vom CDN von Google geladen und übertragen Besucher-IP-Adressen an einen Dritten ohne dokumentierte Rechtsgrundlage — ein bekanntes deutsches Abmahnrisiko	Hoch	Google Fonts vor der Veröffentlichung selbst hosten (bereits eine erfasste Aufgabe vor der Veröffentlichung); die Datenschutzerklärung aktualisieren und den Google-Webfonts-Absatz entfernen. Beseitigt die Übertragung an Dritte vollständig.	Niedrig
CON-03	Nach § 5 TMG konformes Impressum für eine Heilpraktikerin für Psychotherapie	§ 5	Die aktuellen Seiten Impressum und Datenschutz enthalten Demo-Platzhalterinhalte; die Website wird mit Platzhalter- oder rechtlich unvollständigen Rechtsseiten veröffentlicht und setzt Frau Kretzschmar einer Abmahnung aus	Hoch	Echtes Impressum + Datenschutz vor der Veröffentlichung fertiggestellt und anwaltlich geprüft (erfasste Aufgabe vor der Veröffentlichung); die Website kann die Abnahme (AC-07/AC-08) nicht bestehen, bis die Rechtsseiten vollständig und geprüft sind. Das Abnahme-Gate blockiert die Veröffentlichung mit Platzhalter-Rechtsinhalten.	Niedrig
CON-04	Mobile-First-Responsive-Design	§ 5	Die Website wird auf Smartphones/Tablets schlecht dargestellt und verliert den wachsenden Anteil der Patienten, die Praxen mobil entdecken	Mittel	— (abgedeckt durch die Abnahmekriterien AC-01/AC-02, die alle Viewport-Klassen prüfen)	Mittel
CON-05	Gleichrang mit der Website von Dr. Kretzschmar; Birgits Website IST direkt das Parent Theme	§ 5	Da Birgits Website direkt auf <code>praxis_base</code> ohne Child Theme läuft, trifft jede Änderung am Parent Theme — ob für ihre Website beabsichtigt oder für die von Dr. Kretzschmar vorgenommen — ihre Website unmittelbar, ohne Child-Theme-Ebene, die sie abfedert	Hoch	Jede <code>praxis_base</code> -Änderung wird vor der Bereitstellung gegen beide Websites getestet; die Produktivarchitektur hält nach der Migration jede Website auf ihrer eigenen unabhängigen Kopie des Parent Theme; falls eine künftige Änderung nur Birgits Website betreffen soll, wird zunächst ein <code>birgit_child</code> Child Theme angelegt (als bedingte Aufgabe erfasst).	Niedrig

3.2 Umfangsabgrenzungen (URS § 6)

Anf.-ID	Anforderung (kurz)	Quelle	Risiko	Klasse	Mindernde Maßnahme (hohe Risiken)	Rest
SCOPE-01	Die Selbstbearbeitung der Seite Termine ist durch eine eigene, gesonderte URS abgedeckt	§ 6	Der Termine-Editor wird auf Basis der Mutter-URS dieser Risikoanalyse statt seiner eigenen erstellt, oder die beiden Dokumente divergieren	Niedrig	— (die Birgit-Termine-Editor-URS existiert bereits als das maßgebliche Dokument für diese Arbeit)	Niedrig
SCOPE-02	Keine Selbstbearbeitung anderer Seiten	§ 6	Frau Kretzschmar erwartet tatsächlich, Seiten über die Termine hinaus selbst zu bearbeiten; die Annahme ist falsch und zeigt sich erst nach der Veröffentlichung	Mittel	— (der Punkt zu abgeleiteten Anforderungen in URS § 11 bittet Frau Kretzschmar ausdrücklich, dies vor der Freigabe zu bestätigen oder zu korrigieren; wird überwacht)	Mittel
SCOPE-03	Keine Systeme für Terminbuchung, Zahlung oder Patientenaufnahme	§ 6	Der Kunde verlangt später eine Online-Buchung; die Umfangserweiterung wird informell ohne DSGVO-Bewertung gehandhabt	Mittel	— (wird überwacht; eine Buchungsanfrage löst eine neue URS aus)	Mittel
SCOPE-04	Nur deutsch; keine mehrsprachigen Inhalte	§ 6	Internationale Patienten können die Website nicht lesen	Niedrig	—	Niedrig
SCOPE-05	Kein Analytics / kein Tracking durch Dritte	§ 6	Die Praxis möchte später Besucherstatistiken und fügt einen nicht konformen Tracker hinzu	Niedrig	—	Niedrig
SCOPE-06	Kein <code>birgit_child</code> Child Theme, es sei denn, eine ausschließlich Birgit betreffende Änderung wird benötigt	§ 6	Eine ausschließlich Birgit betreffende Änderung wird direkt an <code>praxis_base</code> vorgenommen statt in einem neuen Child Theme und bricht damit den Gleichrang (siehe CON-05)	Mittel	— (die Minderung von CON-05 deckt dies ab: Die Regel lautet, dass eine ausschließlich Birgit betreffende Änderung zuerst das Anlegen von <code>birgit_child</code> auslöst)	Mittel

3.3 Abnahmekriterien (URS § 7)

Anf.-ID	Anforderung (kurz)	Quelle	Risiko	Klasse	Mindernde Maßnahme (hohe Risiken)	Rest
AC-01	Alle elf Seiten werden auf Desktop/Tablet/Mobil dargestellt	§ 7	Eine Seite ist bei einem Viewport zur Veröffentlichung fehlerhaft	Mittel	— (durch die Abnahme-Checkliste vor der Veröffentlichung geprüft)	Mittel
AC-02	Die Hauptnavigation mit Hover-Dropdowns und inline dargestellten mobilen Untermenüs funktioniert auf allen Viewport-Klassen	§ 7	Das Hamburger-Menü oder die Dropdown-Untermenüs versagen auf Mobilgeräten; Patienten können nicht navigieren. Das Hamburger-Menü wird derzeit auf dem Desktop über einen CSS-Workaround ausgeblendet, nicht über eine generierte Tailwind-Utility — ein Zeichen, dass das Navigations-CSS fragil ist	Hoch	Das Tailwind- <code>md:hidden</code> -Scan-Pfad-Problem untersuchen und beheben, sodass die Navigation auf generierten Utilities beruht statt auf einem Workaround; das Hamburger-Menü und die Untermenüs als Teil der Abnahme-Checkliste auf echten Mobilgeräten erneut testen.	Niedrig
AC-03	Startseiten-Hero, Galerie-Raster, CTA-Streifen, Begrüßungstext werden alle aus ACF gerendert und degradieren ordentlich	§ 7	Ein Startseiten-Bereich bricht oder degradiert nicht ordentlich, wenn ein ACF-Feld leer ist	Niedrig	— (die Templates prüfen bereits auf das Vorhandensein der Felder; durch die Abnahme-Checkliste geprüft)	Niedrig
AC-04	Die Seite Termine teilt kommende und vergangene Termine korrekt auf, vergangene aufklappbar	§ 7	Die Datumslogik klassifiziert einen Termin falsch oder die Anzeige der vergangenen Termine versagt — Patienten sehen falsche oder fehlende Termininformationen	Mittel	— (durch die Abnahme-Checkliste geprüft; die Logik ist datumsbasiert und prüfbar)	Mittel
AC-05	Das Kontakt-Formular sendet eine echte E-Mail; DSGVO-Checkbox erforderlich	§ 7	Das Formular versagt in der Produktivumgebung unbemerkt; Patienten Anfragen gehen verloren, ohne dass es jemand bemerkt	Hoch	SMTP- / Kontaktformular-E-Mail-Zustellung in der Produktivumgebung als ausdrückliche Migrationsaufgabe prüfen; vor dem Go-live eine Testanfrage von Anfang bis Ende senden; in den ersten Wochen nach der Veröffentlichung eine Überwachung der Formularzustellung einrichten.	Niedrig
AC-06	Alle Footer-Links lösen auf (keine 404-Fehler)	§ 7	Ein Footer-Link führt zur Veröffentlichung zu einem 404	Mittel	— (durch die Abnahme-Checkliste geprüft)	Mittel
AC-07	Impressum rechtlich vollständig nach § 5 TMG	§ 7	Siehe CON-03 — dieses Abnahmekriterium ist Teil des Gates, das CON-03 durchsetzt	Hoch	Wie CON-03: Die Abnahme kann nicht bestehen, bis das Impressum vollständig und anwaltlich geprüft ist. Das Kriterium ist selbst das Minderungs-Gate.	Niedrig
AC-08	Die Datenschutzerklärung spiegelt die tatsächliche technische Realität wider und ist anwaltlich geprüft	§ 7	Der Datenschutz-Text beschreibt eine andere technische Einrichtung als die Live-Website oder wird ohne anwaltliche Prüfung veröffentlicht	Hoch	Dasselbe Gate wie CON-03: Die Datenschutzerklärung muss anwaltlich geprüft und technisch zutreffend sein (einschließlich der Font-Änderung nach dem Selbsthosten), bevor die Abnahme besteht. Die anwaltliche Prüfung hat die längste externe Vorlaufzeit und wird so früh wie möglich angestoßen.	Niedrig
AC-09	Die Website wird über HTTPS mit gültigem Zertifikat geladen	§ 7	Das Zertifikat ist bei der Umstellung falsch konfiguriert; Browser zeigen eine Sicherheitswarnung	Niedrig	— (Hostinger stellt SSL automatisch bereit; bei der Umstellung geprüft)	Niedrig
AC-10	Die Website wird nicht indexiert, bis das Go-live ausdrücklich freigegeben ist	§ 7	Die Demo- oder Vorab-Website wird von Google indexiert und legt unfertige Inhalte und Platzhalter-Rechtsseiten öffentlich offen	Mittel	— (HTTP-Basic-Auth plus „Suchmaschinen abhalten" für die Demo-Phase bereits eingerichtet)	Mittel
AC-11	Ladezeit der Startseite unter drei Sekunden	§ 7	Eine langsame Startseite verliert Patienten, bevor die Seite gerendert ist	Niedrig	— (das Bild-Audit ist eine erfasste Aufgabe vor der Veröffentlichung)	Niedrig
AC-12	Unveröffentlichter Entwurf der Seite „Praxis" gelöscht	§ 7	Der verwaiste Entwurf wird versehentlich veröffentlicht oder bleibt bestehen und überfrachtet das Backend	Mittel	— (die Löschung ist eine erfasste Aufgabe vor der Veröffentlichung und ein ausdrückliches Abnahmekriterium)	Mittel

3.4 Anforderungen der Build-Spezifikation (URS § 4)

Anf.-ID	Anforderung (kurz)	Quelle	Risiko	Klasse	Mindernde Maßnahme (hohe Risiken)	Rest
BLD-01	Die Website läuft direkt auf <code>praxis_base</code> , kein Child Theme	§ 4.1	Eine praxisspezifische Änderung wird für Birgits Website benötigt und direkt am gemeinsamen Parent Theme vorgenommen, was die Website von Dr. Kretzschmar bricht	Hoch	Die Regel ist in CON-05 und URS § 6 festgehalten: Jede ausschließlich Birgit betreffende Änderung erfordert zunächst das Anlegen eines <code>birgit_child</code> Child Theme. Dies wandelt eine architektonische Gefahr in ein definiertes, abgesichertes Verfahren um.	Niedrig
BLD-02	Inhalte durch ACF-Feldgruppen gesteuert	§ 4.6	Die ACF-Pro-Lizenz läuft ab oder das Plugin wird deaktiviert; alle feldgesteuerten Inhalte verschwinden aus dem Frontend	Hoch	Bestätigen, dass die ACF-Pro-Lizenz aktiv und auf die Produktiv-Website registriert ist; die Lizenz und das Verlängerungsdatum im Übergabematerial dokumentieren; die Theme-Templates prüfen bereits auf das Vorhandensein der Felder, sodass die Website degradiert statt fatal zu fehlern, aber Inhaltsverlust ist dennoch inakzeptabel — die Lizenzkontinuität ist die Minderung.	Niedrig

BLD-03	Alte Domain <code>birgit-kretzschmar.de</code> aus Gründen der SEO-Kontinuität beibehalten; alte URLs wechseln zur neuen <code>/leistungen/...</code> -Struktur	§ 4.2	Alte indexierte URLs (<code>?page_id=X</code> und alte Therapie-Slugs der obersten Ebene) brechen bei der Veröffentlichung; bestehendes Suchmaschinen-Ranking und Patienten-Lesezeichen gehen verloren	Mittel	— (die SEO-Redirect-Map ist eine erfasste Aufgabe vor der Veröffentlichung und wird vor dem Go-live in der Produktivumgebung angewendet)	Mittel
--------	---	-------	---	--------	--	--------

4. Aussage zum Restrisiko

Nach Umsetzung der mindernden Maßnahmen in § 3:

- **Hohe Restrisiken:** keine.
- **Mittlere Restrisiken:** 9 (CON-04, SCOPE-02, SCOPE-03, SCOPE-06, AC-01, AC-04, AC-06, AC-10, AC-12, BLD-03). Diese werden akzeptiert und überwacht; jedes ist entweder durch einen Test der Abnahme-Checkliste, durch einen ausdrücklichen Bestätigungspunkt in URS § 11 oder durch eine erfasste Aufgabe vor der Veröffentlichung abgedeckt.
- **Niedrige Restrisiken:** die übrigen, akzeptiert ohne weitere Maßnahme.

Die hohen Risiken vor Minderung — CON-01, CON-02, CON-03, CON-05, AC-02, AC-05, AC-07, AC-08, BLD-01, BLD-02 — reduzieren sich alle auf niedrig, sobald ihre mindernden Maßnahmen umgesetzt sind. Jede dieser mindernden Maßnahmen ist bereits als Aufgabe im Projektplan oder als Gate in den Abnahmekriterien abgebildet, sodass diese Risikoanalyse keine Arbeit einführt, die nicht bereits geplant ist.

Die einzige wichtigste Minderung speziell für Birgits Website ist die `birgit_child`-Regel (CON-05 / BLD-01): Da ihre Website keine Child-Theme-Ebene hat, ist die Disziplin, vor jeder ausschließlich Birgit betreffenden Änderung am Parent Theme zunächst ein solches anzulegen, das, was beide Websites voreinander schützt.

Ende der Risikoanalyse, Entwurf 1.